UNIVERSIDAD DE LAS FUERZAS ARMADAS ESPE

DEPARTAMENTO DE CIENCIAS DE LA COMPUTACIÓN

INGENIERÍA EN SOFTWARE

PROYECTO INTEGRADOR

Salas de Chat Seguras implementando Esteganografía

Integrantes

Lucas Góngora

Jose Leiton

Asignatura

Desarrollo de Software Seguro

Fecha de presentación

13 de octubre de 2026

Índice de contenidos

1. Criterios de Valoración del Riesgo **1**
1.1. Criterios para la Probabilidad (P) 1
1.2. Criterios para el Impacto (I) 1
1.3. Matriz y Niveles de Riesgo 2

2. Activos **2**

3. Evaluación Analítica del Riesgo Inherente **3**

4. Estrategia de Tratamiento y Controles ISO/IEC 27002 **4**

5. Evaluación del Riesgo Residual y Gobierno del SGSI **5**
5.1. Indicadores clave de desempeño (KPIs) e indicadores clave de riesgo (KRIs) . . . 6

Índice de tablas

1. Escala de probabilidad (P) 1
2. Escala de impacto (I) 1
3. Inventario de activos con sus amenazas y vulnerabilidades asociadas 2
4. Evaluación del riesgo inherente por escenario de amenaza 3
5. Controles propuestos para el tratamiento de los riesgos identificados 5
6. Evaluación del riesgo residual tras el tratamiento propuesto 5

1. Criterios de Valoración del Riesgo

La gestión del riesgo dentro de un Sistema de Gestión de Seguridad de la Información (SGSI) exige formalizar criterios homogéneos para estimar la posibilidad de ocurrencia de un evento adverso y la severidad de sus consecuencias operativas. En el presente trabajo adoptamos una escala ordinal de Likert de 5 niveles, calibrada para relacionar los vectores de ataque sobre servicios web en tiempo real con las necesidades de negocio del sistema de mensajería.

El valor numérico del **Riesgo Inherente** (R) surge del producto entre la Probabilidad (P) y el Impacto (I):

$$R = P \times I$$

1.1. Criterios para la Probabilidad (P)

La escala de probabilidad mide la frecuencia esperada o la facilidad técnica con la que una amenaza puede explotar las debilidades del software (Tabla 1).

Cuadro 1. Escala de probabilidad (P)

Valor	Nivel	Descripción y contexto técnico
1	Muy Baja	Improbable en condiciones normales. Requiere vectores sin antecedentes o exploits desconocidos.
2	Baja	Poco frecuente. Explotación compleja que exige conocimientos avanzados y acceso especializado.
3	Media	Posible. Ocurrencia moderada asociada a vulnerabilidades públicas con scripts conceptuales.
4	Alta	Muy probable. Defecto conocido en OWASP Top 10 que cuenta con herramientas automatizadas de ataque.
5	Muy Alta	Casi seguro o inminente. Amenazas con actividad maliciosa registrada en tiempo real (CISA KEV).

1.2. Criterios para el Impacto (I)

El impacto cuantifica el daño sobre la Confidencialidad, Integridad y Disponibilidad (tríada CIA), así como la degradación del servicio de chat y la exfiltración de información sensible (Tabla 2).

Cuadro 2. Escala de impacto (I)

Valor	Nivel	Efecto en el negocio y la operación
1	Insignificante	Sin alteración perceptible. Leve pérdida de registros secundarios sin exposición de datos.
2	Menor	Afectación localizada. Indisponibilidad breve de funciones accesorias sin compromiso de claves.
3	Moderado	Compromiso parcial en salas aisladas. Interrupción temporal en la transferencia de archivos.
4	Mayor	Exfiltración de chats o datos esteganográficos, elevación de privilegios o caída del motor.
5	Catastrófico	Compromiso total del servidor, ejecución remota de código (RCE) o exfiltración masiva de secretos.

1.3. Matriz y Niveles de Riesgo

El apetito de riesgo define el límite máximo que la organización está dispuesta a tolerar. Los valores resultantes de $P \times I$ se clasifican en tres regiones operativas:

- **Riesgo Bajo (1 a 5):** Región Aceptable. La amenaza está adecuadamente contenida; requiere monitoreo pasivo de mantenimiento.
- **Riesgo Medio / Medio-Alto (6 a 12):** Región Tolerable. Se asume temporalmente mediante planes de remediación a corto plazo dentro del ciclo de desarrollo.
- **Riesgo Alto / Crítico (15 a 25):** Región Inaceptable. Exige tratamiento inmediato mediante controles técnicos prioritarios antes del despliegue a producción.

2. Activos

Para estructurar la protección del software conforme al principio de *Zero Trust* y *Secure by Design*, se han identificado 15 activos esenciales (Tabla 3). La selección no se limita a componentes físicos o bases de datos, sino que abarca procesos de procesamiento binario y claves de sesión. Para cada activo se identifican, además, la amenaza principal y la vulnerabilidad que la hace posible; ambas se retoman en la Sección 3, donde cada par amenaza–vulnerabilidad se formaliza como un escenario de riesgo (RSG) con su probabilidad e impacto.

Filosofía de selección de activos: Bajo el paradigma de Confianza Cero, la frontera de seguridad no es la red externa sino cada dato y proceso individual. Por ello, los archivos subidos por los usuarios se tratan como fuentes no confiables desde su recepción, exigiendo que los motores de análisis y sanitización se consideren activos críticos para la supervivencia del negocio.

Cuadro 3. Inventario de activos con sus amenazas y vulnerabilidades asociadas

ID	Activo	Justificación (CIA, Zero Trust y negocio)	Amenaza	Vulnerabilidad	Riesgo
ACT-01	Pipeline Esteganográfico	Núcleo del negocio. Analiza e inspecciona imágenes para evitar canales encubiertos.	Exfiltración de información mediante un canal encubierto esteganográfico (LSB en PNG).	Ausencia de análisis estadístico y de entropía sobre las imágenes recibidas.	RSG-01
ACT-02	Adjuntos Multimedia	Contenido compartido. Bajo Zero Trust, exige validar ausencia de payloads ocultos.	Ejecución remota de código mediante payloads ocultos en los metadatos del archivo.	Procesamiento de metadatos EXIF sin validación ni eliminación previa.	RSG-02
ACT-03	Claves y Tokens de Sala	Garantizan autenticidad y confidencialidad. Su compromiso expone el chat a intercepción.	Intercepción y robo de claves de sala por parte de un atacante.	Uso de algoritmos criptográficos débiles u obsoletos.	RSG-03
ACT-04	Base de Datos & Credenciales	Almacena identidades y parámetros. Exige máxima protección contra exfiltración o inyección.	Inyección SQL con exposición de hashes y credenciales.	Consultas de autenticación construidas sin parametrización.	RSG-04
ACT-05	API Gateway & WebSockets	Punto de entrada en tiempo real. Su disponibilidad garantiza la continuidad de las salas.	Denegación de servicio (DoS) por inundación de tramas WebSocket.	Ausencia de límites de tasa y de tamaño de mensajes por conexión.	RSG-05

Continúa en la página siguiente

ID	Activo	Justificación (CIA, Zero Trust y negocio)	Amenaza	Vulnerabilidad	Riesgo
ACT-06	Buffer de Cuarentena	Zona temporal de análisis. Requiere aislamiento estricto para prevenir ejecución arbitraria.	Escape de contenedor a partir del análisis de archivos no confiables.	Análisis de adjuntos sin aislamiento suficiente y con privilegios excesivos.	RSG-06
ACT-07	Logs de Auditoría	Esenciales para la trazabilidad y no repudio ante incidentes esteganográficos o intrusiones.	Alteración o borrado de registros para ocultar actividad maliciosa.	Falta de controles de integridad y de almacenamiento remoto de los registros.	RSG-07
ACT-08	Control de Sesión Única	Restringe conexiones simultáneas a un dispositivo activo por usuario, previniendo secuestros.	Secuestro de sesión mediante reutilización del token desde varios clientes.	El token no se invalida ante conexiones concurrentes desde otros dispositivos.	RSG-08
ACT-09	Consola de Administración	Permite gestionar y cerrar salas. Su compromiso compromete todo el entorno.	Suplantación de identidad de un administrador.	Ausencia de autenticación multifactor (MFA) en cuentas privilegiadas.	RSG-09
ACT-10	Motor Cifrado E2EE / TLS	Asegura la privacidad punto a punto. Su falla expone el texto plano de las conversaciones.	Ataque Man-in-the-Middle sobre el canal cifrado.	Falta de validación de los certificados TLS.	RSG-10
ACT-11	Archivos de Configuración	Definen umbrales de detección y políticas de bloqueo. Su alteración inactiva las defensas.	Modificación no autorizada de las políticas de seguridad.	Permisos laxos sobre los archivos de configuración.	RSG-11
ACT-12	Infraestructura de Red	Mantiene el enrutamiento y previene la degradación por ataques volumétricos DoS.	Saturación de conexiones por peticiones masivas.	Ausencia de limitación de solicitudes (*rate limiting*) y de filtrado de tráfico.	RSG-12
ACT-13	Módulo Sanitizador / Re-coder	Destruye datos ocultos mediante stripping EXIF y re-muestreo de matrices de píxeles.	Evasión del sanitizador mediante compresión maliciosa de píxeles.	Recodificación incompleta que preserva datos ocultos en la matriz de píxeles.	RSG-13
ACT-14	Contenedor Docker	Entorno de ejecución aislada. Evita ataques de escape de contenedor hacia el host.	Escalada de privilegios hacia el host desde el contenedor.	Ejecución del contenedor en modo privilegiado, sin perfiles restrictivos.	RSG-14
ACT-15	Sistema de Alerta Inmediata	Notifica en tiempo real los hallazgos de archivos alterados para desencadenar respuesta.	Omisión de alertas ante la detección de esteganografía.	Ausencia de generación y notificación automática de alertas (sin integración SIEM).	RSG-15

3. Evaluación Analítica del Riesgo Inherente

A partir del inventario de activos, y de la amenaza y la vulnerabilidad identificadas para cada uno (Tabla 3), formulamos un escenario de riesgo específico. Cada amenaza se vincula con la taxonomía internacional correspondiente (Common Weakness Enumeration – CWE, OWASP Top 10:2025 y CAPEC) y se califica numéricamente para determinar el Riesgo Inherente (R_i), como se muestra en la Tabla 4.

Cuadro 4. Evaluación del riesgo inherente por escenario de amenaza

Riesgo	Activo	Escenario de amenaza y vulnerabilidad	Taxonomía	P	I	R_i
RSG-01	ACT-01	Exfiltración por canal encubierto LSB en PNG sin análisis de entropía.	CWE-1008 / CAPEC-52	4	5	**20**
RSG-02	ACT-02	Ejecución remota de código por payloads ocultos en metadatos EXIF.	CWE-94 / OWASP A05	4	5	**20**
RSG-03	ACT-03	Intercepción y robo de claves de sala por uso de algoritmos débiles.	CWE-327 / OWASP A04	3	5	**15**

Continúa en la página siguiente

Riesgo	Activo	Escenario de amenaza y vulnerabilidad	Taxonomía	P	I	R_i
RSG-04	ACT-04	Inyección SQL en autenticación que expone hashes y credenciales.	CWE-89 / OWASP A05	4	5	**20**
RSG-05	ACT-05	Denegación de servicio (DoS) por inundación de tramas WebSocket.	CWE-400 / OWASP A06	4	4	**16**
RSG-06	ACT-06	Escape de contenedor derivado del análisis de archivos en buffer.	CWE-250 / CAPEC-17	3	5	**15**
RSG-07	ACT-07	Alteración de logs de auditoría por falta de controles de integridad.	CWE-117 / OWASP A09	3	4	**12**
RSG-08	ACT-08	Reutilización paralela del token de sesión desde múltiples clientes.	CWE-613 / OWASP A01	4	4	**16**
RSG-09	ACT-09	Suplantación de identidad admin por ausencia de autenticación MFA.	CWE-308 / OWASP A07	3	5	**15**
RSG-10	ACT-10	Intercepción Man-in-the-Middle por falta de validación de cert TLS.	CWE-295 / OWASP A04	3	4	**12**
RSG-11	ACT-11	Alteración de políticas de archivos por permisos laxos en configuración.	CWE-732 / OWASP A02	3	4	**12**
RSG-12	ACT-12	Saturación de conexiones por peticiones masivas sin Rate Limiting.	CWE-770 / OWASP A06	4	3	**12**
RSG-13	ACT-13	Evasión del sanitizador mediante compresión maliciosa de píxeles.	CWE-693 / CAPEC-66	4	4	**16**
RSG-14	ACT-14	Ejecución de contenedor en modo privilegiado permitiendo escalada.	CWE-250 / OWASP A02	3	5	**15**
RSG-15	ACT-15	Omisión de alertas automáticas ante la detección de esteganografía.	CWE-390 / OWASP A09	3	3	**9**

4. Estrategia de Tratamiento y Controles ISO/IEC 27002

Para mitigar los escenarios identificados, se proponen controles técnicos basados en la norma **ISO/IEC 27002:2022**, complementados con prácticas de desarrollo seguro de **NIST SP 800-218 (SSDF)**.

Núcleo técnico antiesteganografía: estrategia destructiva en dos fases
La estrategia propuesta combina el análisis inicial de los archivos con la transformación de aquellos que se admitan para su procesamiento:

1. *Análisis estadístico:* inspección del archivo mediante el cálculo de la entropía de Shannon y pruebas estadísticas, como chi-cuadrado, sobre el histograma de colores. Un valor de entropía superior a 7.95 puede utilizarse como señal de alerta, pero no constituye por sí solo una prueba concluyente de esteganografía.
2. *Sanitización destructiva:* eliminación de metadatos EXIF/IPTC y decodificación y recodificación de la imagen mediante un proceso controlado de remuestreo y renderizado de la matriz de píxeles. Esta transformación busca eliminar datos ocultos en los planos de bits menos significativos (LSB) y otros contenidos que no sean necesarios para la representación visual.

La aplicación de estas medidas debe complementarse con límites de tamaño, validación del formato real del archivo y procesamiento aislado. La detección estadística y la recodificación reducen determinados riesgos, pero no garantizan la eliminación de todas las técnicas esteganográficas.

Matriz de controles propuestos. La Tabla 5 relaciona cada escenario de riesgo con el control técnico propuesto y su referencia normativa.

Cuadro 5. Controles propuestos para el tratamiento de los riesgos identificados

Riesgo	Control aplicado	Especificación técnica y estándar referencial
RSG-01	Inspección estadística y LSB	Análisis de entropía de Shannon y prueba chi-cuadrado como señales de detección. (ISO/IEC 27002:2022, control 8.28)
RSG-02	Eliminación de EXIF y recodificación	Recodificación mediante Pillow o ImageMagick, con eliminación de metadatos y renderizado de píxeles. (Control 8.14)
RSG-03	Gestión criptográfica	AES-256-GCM para datos en reposo y establecimiento de claves mediante ECDHE en tránsito. (Control 8.24)
RSG-04	Consultas parametrizadas	Uso obligatorio de consultas parametrizadas y análisis estático de código (SAST) en CI/CD. (Control 8.28)
RSG-05	Control de búfer y tasa	Limitación de mensajes por WebSocket y tamaño máximo de los archivos adjuntos. (Control 8.6)
RSG-06	Cuarentena aislada	Análisis de adjuntos en contenedores efímeros sin privilegios y con acceso de red restringido. (Control 8.31)
RSG-07	Protección de registros	Envío a Syslog remoto y almacenamiento protegido contra modificaciones; uso de mecanismos de integridad verificable. (Control 8.15)
RSG-08	Control de sesiones	Validación del identificador de dispositivo activo por usuario mediante Redis. (Control 8.5)
RSG-09	Autenticación multifactor	MFA con TOTP o WebAuthn para el panel administrativo y controles contra intentos reiterados. (Control 5.17)
RSG-10	Protección de comunicaciones	Configuración segura de TLS, uso de HSTS cuando corresponda y validación adecuada de certificados. (Control 8.20)
RSG-11	Gestión de configuración	Permisos restrictivos para archivos y monitorización de la integridad de ficheros (FIM). (Control 8.9)
RSG-12	Filtrado de tráfico	WAF, reglas de filtrado y limitación de solicitudes para reducir ataques web y abuso de recursos. (Control 8.20)
RSG-13	Remuestreo destructivo	Conversión y recodificación de imágenes para dificultar la persistencia de datos ocultos en representaciones no necesarias. (Control 8.14)
RSG-14	Restricción de contenedores	Contenedores de solo lectura cuando sea viable y perfiles restrictivos de AppArmor o Seccomp. (Control 8.8)
RSG-15	Monitorización y alertas	Generación de alertas e integración con SIEM mediante comunicaciones autenticadas y protegidas. (Control 8.16)

5. Evaluación del Riesgo Residual y Gobierno del SGSI

Una vez definidos los controles para el tratamiento de los riesgos, se realiza una reevaluación de la probabilidad residual (P_r) y del impacto residual (I_r). El riesgo residual (R_r) se calcula mediante el producto de ambos valores, conforme a la escala de valoración establecida en la metodología de análisis. La Tabla 6 presenta los resultados estimados para los quince escenarios identificados.

Cuadro 6. Evaluación del riesgo residual tras el tratamiento propuesto

Riesgo	R_i	Mecanismo de mitigación	P_r	I_r	R_r	Estado final
RSG-01	20	Inspección multifase de entropía	2	3	**6**	Tolerable (medio)
RSG-02	20	Eliminación de metadatos EXIF y recodificación	1	3	**3**	Aceptable (bajo)
RSG-03	15	Cifrado AES-256-GCM y ECDHE	1	4	**4**	Aceptable (bajo)
RSG-04	20	Consultas parametrizadas y análisis SAST	1	4	**4**	Aceptable (bajo)
RSG-05	16	Limitación de tasa en WebSockets	2	2	**4**	Aceptable (bajo)
RSG-06	15	Cuarentena en contenedor efímero	1	3	**3**	Aceptable (bajo)
RSG-07	12	Registro remoto Syslog con cadena de hashes	1	3	**3**	Aceptable (bajo)
RSG-08	16	Invalidación de sesiones mediante Redis	2	2	**4**	Aceptable (bajo)
RSG-09	15	Autenticación multifactor: TOTP y WebAuthn	1	3	**3**	Aceptable (bajo)
RSG-10	12	TLS 1.3 y configuración estricta de certificados	1	3	**3**	Aceptable (bajo)
RSG-11	12	Refuerzo de permisos y monitorización de integridad (FIM)	1	3	**3**	Aceptable (bajo)
RSG-12	12	WAF ModSecurity y limitación de tasa	2	2	**4**	Aceptable (bajo)
RSG-13	16	Remuestreo destructivo de píxeles	2	2	**4**	Aceptable (bajo)

Continúa en la página siguiente

Riesgo	R_i	Mecanismo de mitigación	P_r	I_r	R_r	Estado final
RSG-14	15	Contenedores Docker de solo lectura y AppArmor	1	3	**3**	Aceptable (bajo)
RSG-15	9	Webhooks de alerta e integración con SIEM	1	2	**2**	Aceptable (bajo)

Hallazgo de gobierno del SGSI (ISO/IEC 27001:2022).
La evaluación inicial indica que 10 de los 15 escenarios (aproximadamente el 67 %) presentan un riesgo inherente igual o superior a 15 ($R_i \geq 15$), según la escala definida. Esto refleja la exposición inicial del sistema a amenazas relacionadas con la esteganografía, la gestión de sesiones y otros componentes de seguridad.
De acuerdo con las estimaciones de tratamiento, los quince escenarios alcanzarían valores de riesgo residual entre 2 y 6 ($R_r \leq 6$). Estos resultados se sitúan dentro del umbral de aceptación establecido para este análisis ($R \leq 6$). Sin embargo, deben interpretarse como valores estimados: su confirmación requiere implementar los controles, comprobar su eficacia y documentar la aceptación del riesgo residual.

5.1. Indicadores clave de desempeño (KPIs) e indicadores clave de riesgo (KRIs)

Para supervisar la eficacia de los controles y apoyar la mejora continua del SGSI mediante el ciclo PHVA (Planificar, Hacer, Verificar y Actuar), se proponen los siguientes indicadores operativos:

- **Efectividad de la sanitización de archivos:** porcentaje de archivos de prueba con cargas esteganográficas conocidas que son detectadas o neutralizadas correctamente. La meta deberá establecerse a partir de pruebas reproducibles; no debe asumirse una efectividad superior al 99.8 % sin evidencia experimental.
- **Tiempo medio de detección (MTTD):** tiempo promedio transcurrido desde la recepción de un archivo hasta la detección de una anomalía o amenaza. Se medirá mediante pruebas de carga y registros de tiempo.
- **Cobertura de MFA en cuentas administrativas:** porcentaje de cuentas privilegiadas que tienen habilitada y verificada la autenticación multifactor. Meta propuesta: 100 %.
- **Vulnerabilidades críticas abiertas en producción:** número de vulnerabilidades críticas confirmadas y pendientes de remediación, identificadas mediante análisis SAST, DAST y otras pruebas pertinentes. Meta propuesta: cero vulnerabilidades críticas abiertas.